

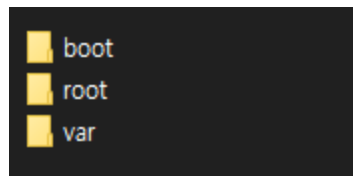
11/01) CTF 문제풀이 (1)

▼ Insider Blue Team Challenge



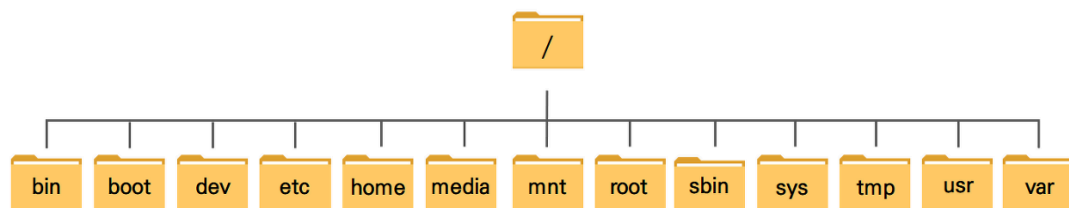
Karen이 리눅스로 저지른 불법적인 일 확인하기

일단 [root] 파일 export 함



리눅스 디렉터리 구조 먼저 찾아보았다.

▼ 리눅스 파일 시스템과 구조 (출처)



- bin

binarys의 약자, 시스템 운영을 위한 기본 명령어들이 있음

- boot

부팅에 핵심적인 커널 이미지와 부팅 정보 파일 담고 있음

- dev

장치파일 저장, 연결되어 있는 장치 정보 확인

- etc

시스템 환경 설정 파일 있음

네트워크 관련 설정 파일, 사용자 정보 및 암호정보, 파일 시스템 정보, 보안 파일 등

- home

리눅스 사용자의 홈 디렉토리가 만들어지는 디렉토리

- media

CD_ROM이나 USB같은 외부 장치 연결하는 디렉토리

- mnt

파일 시스템을 임시로 연결하는 디렉토리

- root

시스템 관리자의 홈 디렉토리. 일반 사용자 접근 불가

- sbin

bin과 유사하지만 오직 루트유저만 실행할 수 있는 프로그램들이 있음

- sys

리눅스 커널관련 정보 있는 곳

- tmp

시스템 사용 중 발생한 임시 데이터 저장되는 곳

부팅 시 초기화

- usr

기본 실행파일과 라이브러리 파일, 헤더 파일 등이 저장된 곳

대부분의 응용프로그램과 파일 저장

- var

시스템 운영 중 발생한 데이터와 로그가 저장되는 곳

Q1. Distribution of Linux (distro of Linux)

A1. kali

/boot/ 들어가면 알 수 있음

grub	2023-10-30 오후 2:43	파일 폴더
config-4.13.0-kali1-amd64	2017-11-08 오후 5:32	0-KALI1-AMD64 ...
initrd.img-4.13.0-kali1-amd64	2019-03-14 오후 12:33	0-KALI1-AMD64 ...
System.map-4.13.0-kali1-amd64	2017-11-08 오후 5:32	0-KALI1-AMD64 ...
vmlinuz-4.13.0-kali1-amd64	2017-11-08 오후 5:32	0-KALI1-AMD64 ...

Q2. MD5 hash of the apache access.log

A2. 모르겠다...머임

access.log 비어 있는데 복구를 하는 걸까 아니면 다른 데서 찾는 걸까
구글링

```
PS D:\포렌식\6주차(11.1)\c46-FirstHack> Get-FileHash -algorithm MD5 access.log

Algorithm      Hash
-----
MD5            D41D8CD98F00B204E9800998ECF8427E
```

access.log 파일 있는 곳으로 가서 **Get-FileHash -algorithm MD5 access.log**

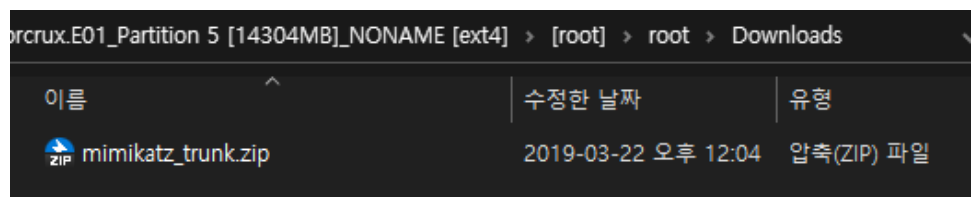
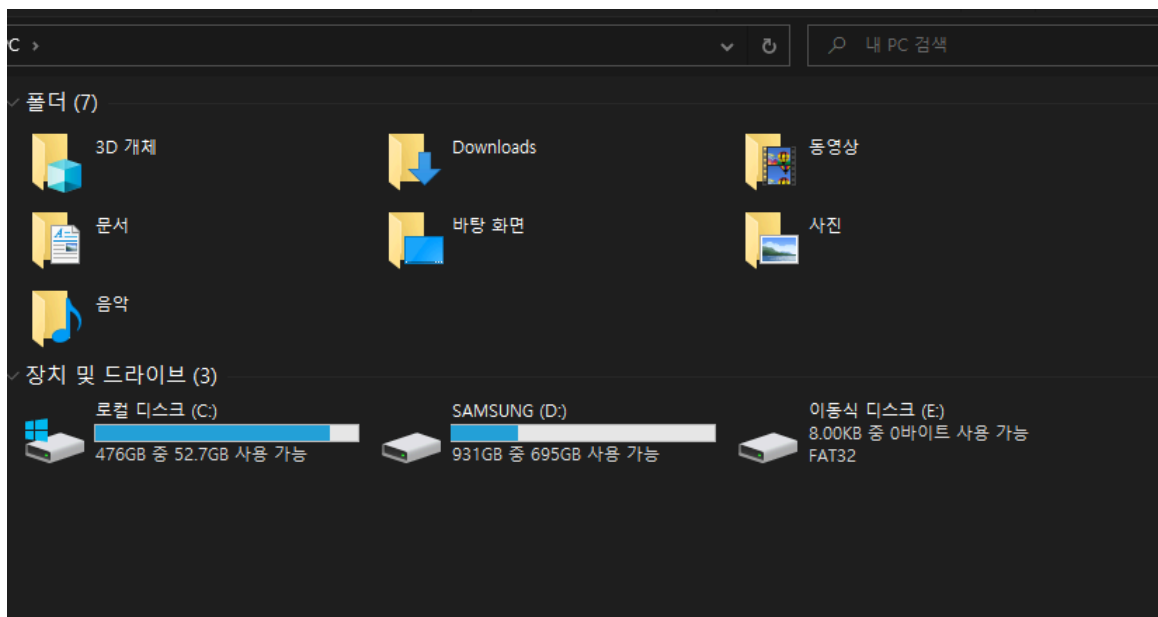
근데 [root] 파일은 경로에 안 써진다

Q3. name of credential dumping tool

A3. 이것도 모르겠다

패키지 설치 로그를 살펴봐도 나오지 않음

구글링



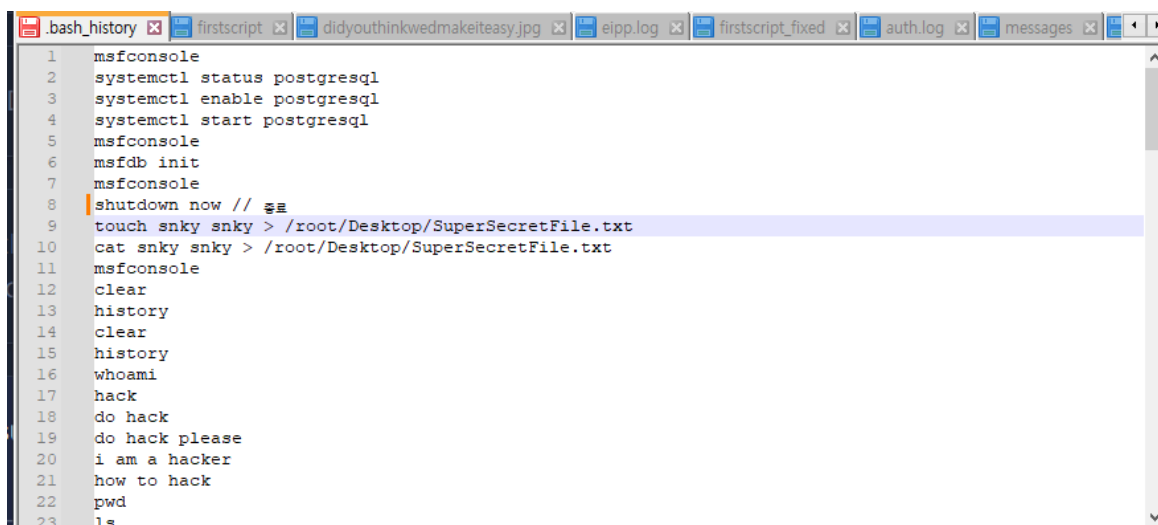
파일 추출 하는 걸로는 안 보인다.

root-downloads에 있음

Q4. super-secret file 의 절대경로

A4. /root/Desktop/SuperSecretFile.txt

.bash_history에서 찾을 수 있다.



Q5. didyouthinkwedmakeiteasy.jpg를 사용한 프로그램 이름

A5. binwalk

마찬가지로 .bash_history에서 binwalk 라는 명령어와 함께 사용된 걸 볼 수 있다.

- binwalk란?

펌웨어 분석 도구, 칼리 리눅스에 내장되어 있음

binwalk <파일명> 입력하면 해당 파일에 숨겨진 파일들 찾을 수 있음

```
.bash_history x firstscript x didyouthinkwedmakeiteasy.jpg x eipp.log x firstscript_fixed x auth.log x messages x
76 echo "If you're still reading this file, scream cake."
77 echo "Seriously, we'll give you a hint to answer question if you scream cake."
78 sudo visudo
79 ls
80 sudo ifng
81 ifconfi
82 apt get moo
83 sudo apt get moo
84 sudo apt install moo
85 sudo apt-install moo
86 sudo apt-get install moo
87 lol Castro just failed at all these commands. Someone pat him on the back.
88 I tried okay
89 history > history.txt
90 binwalk didyouthinkwedmakeiteasy.jpg
91 clear
92 history
93 exit
94 touch keys.txt
95 pwd
96
```

Q6. checklist에서 Karen의 third goal

A6. Profit

```
Check List:
- Gain Bob's Trust
- Learn how to hack
- Profit
```

무슨 의도로 낸 문제인지 모르겠음

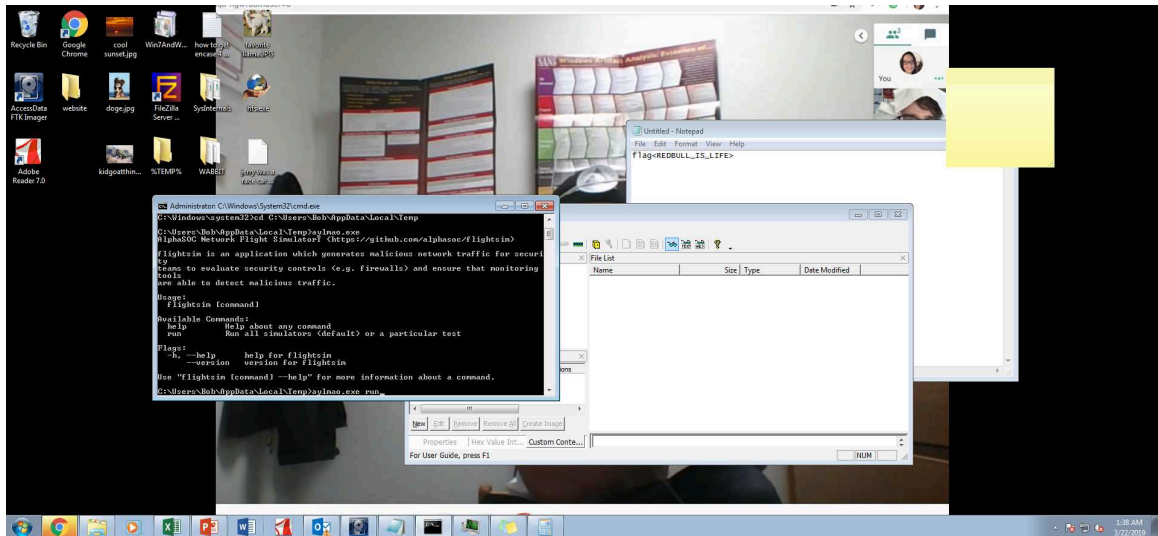
Q7. apache 몇 번 실행됐는지

A7. 😊

access.log 파일이 0kb → 아직 실행이 안 됐다는 뜻이었음

Q8. 다른 컴퓨터 공격한 증거 파일

A8. irZLAohl.jpeg



사실 이게 왜 답인지 잘 모르겠다.

Q9. Karen이 taunting하는 사람 이름

A9. 🤔 구글링

Castro인 줄 알았는데...

Young이 사람 이름이었음

```
echo "Showing you your current path"
pwd
echo "Show my default route"
ip route | grep --color default
echo "Show network connections w/ port 80"
netstat | grep --color 80
echo "Heck yeah! I can write bash too Young"
```

Q10. 11시 26분에 여러 번 su 한 사람이 누군가?

A11. postgres

사용자 로그인이나 사용된 인증방법이 기록되는 **auth.log**를 살펴봄

그리고보니 처음에 Karen이 postgresql 실행한 것 봤었는데 이 프로그램으로 접근한 듯?

그냥 sql프로그램 같은데... 어떻게 한 걸까

<su>

substitute user의 줄임말로 다른 계정으로 전환하는 리눅스 명령어이다. 로그아웃하지 않고 다른 사용자의 권한으로 셸을 실행하는 데 사용된다.

```
D:\#포렌식#6주차(11.1)\#c46-FirstHack#\root#\var\log\auth.log - Notepad++
파일(F) 편집(E) 찾기(S) 보기(V) 인코딩(N) 언어(L) 설정(I) 도구(O) 매크로 실행 플러그인 창 관리 ?
history.log firstscript_fixed auth.log messages dpkg.log user.log Xorg.1.log
1174 user root by (uid=0)
1175 Mar 20 11:23:42 KarenHacker systemd: pam_unix(systemd-user:session): session opened for user root
1176 Mar 20 11:23:42 KarenHacker systemd-logind[455]: New session 589 of user root.
1177 Mar 20 11:23:45 KarenHacker polkitd(authority=local): Registered Authentication Agent for
1178 Mar 20 11:25:01 KarenHacker CRON[3910]: pam_unix(cron:session): session opened for user root by
1179 Mar 20 11:26:22 KarenHacker su[4060]: Successful su for postgres by root
1180 Mar 20 11:26:22 KarenHacker su[4060]: + ??? root:postgres
1181 Mar 20 11:26:22 KarenHacker su[4060]: pam_unix(su:session): session opened for user postgres by
1182 Mar 20 11:26:22 KarenHacker su[4060]: pam_systemd(su:session): Cannot create session: Already
1183 Mar 20 11:26:22 KarenHacker su[4060]: pam_unix(su:session): session closed for user postgres
1184 Mar 20 11:26:22 KarenHacker su[4074]: Successful su for postgres by root
1185 Mar 20 11:26:22 KarenHacker su[4074]: + ??? root:postgres
1186 Mar 20 11:26:22 KarenHacker su[4074]: pam_unix(su:session): session opened for user postgres by
1187 Mar 20 11:26:22 KarenHacker su[4074]: pam_systemd(su:session): Cannot create session: Already
1188 Mar 20 11:26:22 KarenHacker su[4081]: Successful su for postgres by root
1189 Mar 20 11:26:22 KarenHacker su[4081]: + /dev/pts/0 root:postgres
1190 Mar 20 11:26:22 KarenHacker su[4081]: pam_unix(su:session): session opened for user postgres
1191 Mar 20 11:26:22 KarenHacker su[4081]: pam_unix(su:session): session opened for user postgres

찾기 결과들 - (30 일치)
찾기 "11:26" (11 개 파일을 검색하여 1 개 파일에서 30 개 일치)
D:\#포렌식#6주차(11.1)\c46-FirstHack\root\var\log\auth.log (30 일치)
줄 1179: Mar 20 11:26:22 KarenHacker su[4060]: Successful su for postgres by root
줄 1180: Mar 20 11:26:22 KarenHacker su[4060]: + ??? root:postgres
줄 1181: Mar 20 11:26:22 KarenHacker su[4060]: pam_unix(su:session): session opened for user postgres
줄 1182: Mar 20 11:26:22 KarenHacker su[4060]: pam_systemd(su:session): Cannot create session: Already
줄 1183: Mar 20 11:26:22 KarenHacker su[4060]: pam_unix(su:session): session closed for user postgres
줄 1184: Mar 20 11:26:22 KarenHacker su[4074]: Successful su for postgres by root
줄 1185: Mar 20 11:26:22 KarenHacker su[4074]: + ??? root:postgres
줄 1186: Mar 20 11:26:22 KarenHacker su[4074]: pam_unix(su:session): session opened for user postgres
줄 1187: Mar 20 11:26:22 KarenHacker su[4074]: pam_systemd(su:session): Cannot create session: Already
줄 1188: Mar 20 11:26:22 KarenHacker su[4074]: pam_unix(su:session): session closed for user postgres
줄 1189: Mar 20 11:26:22 KarenHacker su[4081]: Successful su for postgres by root
줄 1190: Mar 20 11:26:22 KarenHacker su[4081]: + /dev/pts/0 root:postgres
줄 1191: Mar 20 11:26:22 KarenHacker su[4081]: pam_unix(su:session): session opened for user postgres

Normal text file length: 191,845 lines: 1,939 Ln: 1,179 Col: 13 Sel: 5 | 1 Unix (LF) UTF-8 INS
```

Q11. bash history를 봤을 때, 현재 디렉토리는?

A11. /root/Documents/myfirsthack/

- .bash_history: 리눅스에서 로그인한 순간부터 입력된 커맨드가 기록된 파일
- msfconsole (Metasploit)

: CVE 넘버링이 붙은, 알려진 취약점 공격을 사용할 수 있도록 제공되는 도구.

해킹을 간단하게 하도록 도와주는 모의 해킹 도구

- CVE란?

: Common Vulnerabilities and Exposure. 공개적으로 알려진 소프트웨어 보안 취약점을 가리키는 고유 표기 . CVE+취약점 발견된 연도+임의의 번호 붙여서 만들어짐

- postgresql

: 객체-관계형 데이터베이스 프로그램

- touch 명령어

: 파일의 생성과 날짜, 시간을 변경하는 명령어

- sudo란 (Q. su랑 다른 건가?)

- super user do의 약자
- 유닉스 및 리눅스 계열에서 다른 사용자의 보안 권한과 관련된 프로그램 구동할 수 있게 도와줌
- etc/sudoers 파일에 지정된 사용자만 sudo 명령어 사용 가능
- 현재 계정에서 다른 계정의 권한만 빌림
- root가 아닌 사용자가 root에 준하는 능력으로 sudo 다음에 나오는 명령을 실행하게 하는 명령어

- apt란?

- Advanced Package Tool의 약자
- Debian 시스템에 포함된 핵심 도구들의 집합체
- 응용 프로그램 설치, 삭제, 최신 버전으로 유지 등 가능

- 패키지란?

: 커널 및 라이브러리 버전의 배포판 환경에 맞추어 빌드한 실행파일을 압축한 것

- 리눅스 로그파일

: /var/에서 볼 수 있다

▼ RedLine Blue Team Challenge

1. NIDS를 어떻게 뚫었는지 찾기

2. malware family 찾기
3. 공격자가 남긴 흔적 찾기
 - Volatility 이용

▼ pip install 안 될 때

환경변수 편집해주기... 는 했는데 안 됨



인스톨러 실행해서 modify → path에 추가 옵션 선택하면 된다

```
C:\Windows\System32\cmd.exe
yara\libyara\modules\math\math.c(458): warning C4018: '<': signed 또는 unsigned가 일치하지 않습니다.
yara\libyara\modules\math\math.c(463): warning C4018: '<': signed 또는 unsigned가 일치하지 않습니다.
yara\libyara\modules\math\math.c(509): warning C4018: '>': signed 또는 unsigned가 일치하지 않습니다.
"C:\Program Files\Microsoft Visual Studio\2022\Community\VC\Tools\MSVC\14.32.31326\bin\Hostx86\x64\cl.exe" /c /nologo /O2 /W3 /GL /DNDEBUG /MD -DBUCKETS_128=1 -DCHECKSUM_1B=1 -DUSE_WINDOWS_PROC=1 -D_CRT_SECURE_NO_WARNINGS=1 -DHAVE_STD_BOOL_H=1 -DHASH_MODULE=1 -DHAVE_WINCRIPT_H=1 -DDOTNET_MODULE=1 -Iyara/libyara/include -Iyara/libyara/ -I. -IC:\Users\PRO\AppData\Local\Programs\Python\Python312\include -IC:\Users\PRO\AppData\Local\Programs\Python\Python312\include -IC:\Program Files\Microsoft Visual Studio\2022\Community\VC\Tools\MSVC\14.32.31326\include -IC:\Program Files\Microsoft Visual Studio\2022\Community\VC\Tools\MSVC\14.32.31326\ATLMFC\include -IC:\Program Files\Microsoft Visual Studio\2022\Community\VC\Tools\MSVC\14.32.31326\include -IC:\Program Files (x86)\Windows Kits\10\include\10.0.19041.0\ucrt" "-IC:\Program Files (x86)\Windows Kits\10\include\10.0.19041.0\shared" "-IC:\Program Files (x86)\Windows Kits\10\include\10.0.19041.0\um" "-IC:\Program Files (x86)\Windows Kits\10\include\10.0.19041.0\winrt" "-IC:\Program Files (x86)\Windows Kits\10\include\10.0.19041.0\cppwinrt" /Tcyara\libyara\modules\pe\authenticode-parser\authenticode.c /Fobuild\temp.win-amd64-cpython-312\Release\yara\libyara\modules\pe\authenticode-parser\authenticode.obj
yara\libyara\modules\pe\authenticode-parser\authenticode.c(22): fatal error C1083: 포함 파일을 열 수 없습니다. 'openssl\asn1.h': No such file or directory
error: command 'C:\Program Files\Microsoft Visual Studio\2022\Community\VC\Tools\MSVC\14.32.31326\bin\Hostx86\x64\cl.exe' failed with exit code 2
[End of output]

note: This error originates from a subprocess, and is likely not a problem with pip.
ERROR: Failed building wheel for yara-python
Failed to build yara-python
ERROR: Could not build wheels for yara-python, which is required to install pyproject.toml-based projects

[notice] A new release of pip is available: 23.2.1 -> 23.3.1
[notice] To update, run: C:\Users\PRO\AppData\Local\Programs\Python\Python312\python.exe -m pip install --upgrade pip
C:\Users\PRO\바탕 화면\3-2\IHHL_Forensic\volatility3-2.4.1\volatility3-2.4.1>
```

volatility3를 활용한 메모리 분석 (2) - Ubuntu Linux : 포스타입 포스트

앞서 volatility3 을 이용해 윈도우 메모리 포렌식을 수행하는 방법을 설명했다. 요약해서 한번 더 언급하자면, 메모리 포렌식 프레임워크인 Volatility 의 최초 버전은 2007년 Black Hat DC 에서 공개되었다. 파이썬2를 이용하여 지속 개발되던 볼라

 <https://cpuu.postype.com/post/11807930>

Volatility3 Linux ISF Server

Volatility 3.0.0 generated symbol packs for a range of Linux kernels on Ubuntu. You can search for the full kernel as shown in Volatility 3 banners, banners only. If the pack exists you will be provided with a download link or a json file. These links are only valid for 1 hour then you will have to search

5.4.0-generic

Banner

5.4.0-generic (built by cy01 on 04-02-20) [gcc version 9.3.0 (Ubuntu 9.3.0-10ubuntu2)] #20-Ubuntu SMP Mon Apr 2

vol3 부터는 기존의 profile이라는 개념이 아닌 Symbol Table을 사용한다고 한다.

커널의 심볼 정보들이 등록되어 있는 테이블을 기준으로 해석하여 메모리 내의 값들의 의미를 찾아낼 수 있도록 하는 것.

커널의 심볼 테이블을 분석하여 특별한 포맷인 ISF(Intermediate Symebole Format) 파일 형식으로 저장한다.

정확히 이해는 안 되지만 imageinfo의 결과가 바뀌었다.



```
python3 vol.py -f .\MemoryDump.mem windows.info.Info
```

```
Windows PowerShell
Progress: 99.99      Reading Symbol layer
Progress: 99.99      Reading Symbol layer
Progress: 100.00     Reading Symbol layer
Progress: 100.00     Reading Symbol layer
Progress: 100.00     PDB scanning finished

Variable           Value
-----
Kernel Base        0xf8076221a000
DTB                 0x1ad000
Symbols file: //C:/Users/PRO/%EB%B0%94%ED%83%95%20%ED%99%94%EB%A9%B4/3-2/IHHH_Forensic/volatility3-2.4.1/volatility3-2.4.1/volatility3/symbols/windows/ntkrnlmp.pdb/68A17FAF3012B7846079AEEDBE0A583-1.json.xz
Is64Bit            True
IsPAE              False
layer_name         0 WindowsIntel32e
memory_layer       1 FileLayer
KdVersionBlock     0xf80762e29398
Major/Minor        15.19041
MachineType        34404
KeNumberProcessors 4
SystemTime         2023-05-21 23:02:39
NtSystemRoot       C:\Windows
NtProductType      NtProductWinT
NtMajorVersion     10
NtMinorVersion     0
PE MajorOperatingSystemVersion 10
PE MinorOperatingSystemVersion 0
PE Machine         34404
PE TimeDateStamp   Wed Jun 28 04:14:26 1995
PS C:\Users\PRO\바탕 화면\3-2\IHHH_Forensic\volatility3-2.4.1\volatility3-2.4.1>
```

Q1, Q2. suspicious process & child process of the process

A1, A2. oneetx.exe & rundll32.exe

윈도우 서비스들 제외하고 모르는 것들 구글링해서 찾았다.

oneetx는 Amadey(dropper??)가 뿌리는 맬웨어라고 함

```
python3 vol.py -f .\MemoryDump.mem windows.pslist.PsList > pslist.log
```

```
python3 vol.py -f .\MemoryDump.mem windows.pstree.PsTree
```

*** 3252	3580	vmtoolsd.exe	0xad8189796300	8	-	1	False	2023-05-21 22:31:59.000000	N/A
*** 2228	3580	FTK Imager.exe	0xad818d143080	10	-	1	False	2023-05-21 22:43:56.000000	N/A
*** 8920	3580	FTK Imager.exe	0xad818ef81080	20	-	1	False	2023-05-21 23:02:28.000000	N/A
* 860	588	fontdrvhost.exe	0xad81876f1f00	5	-	1	False	2023-05-21 22:27:33.000000	N/A
5896	8844	oneetx.exe	0xad8189b41080	5	-	1	True	2023-05-21 22:30:56.000000	N/A
* 7732	5896	rundll32.exe	0xad818d1912c0	1	-	1	True	2023-05-21 22:31:53.000000	N/A

A3. PAGE_EXECUTE_READWRITE

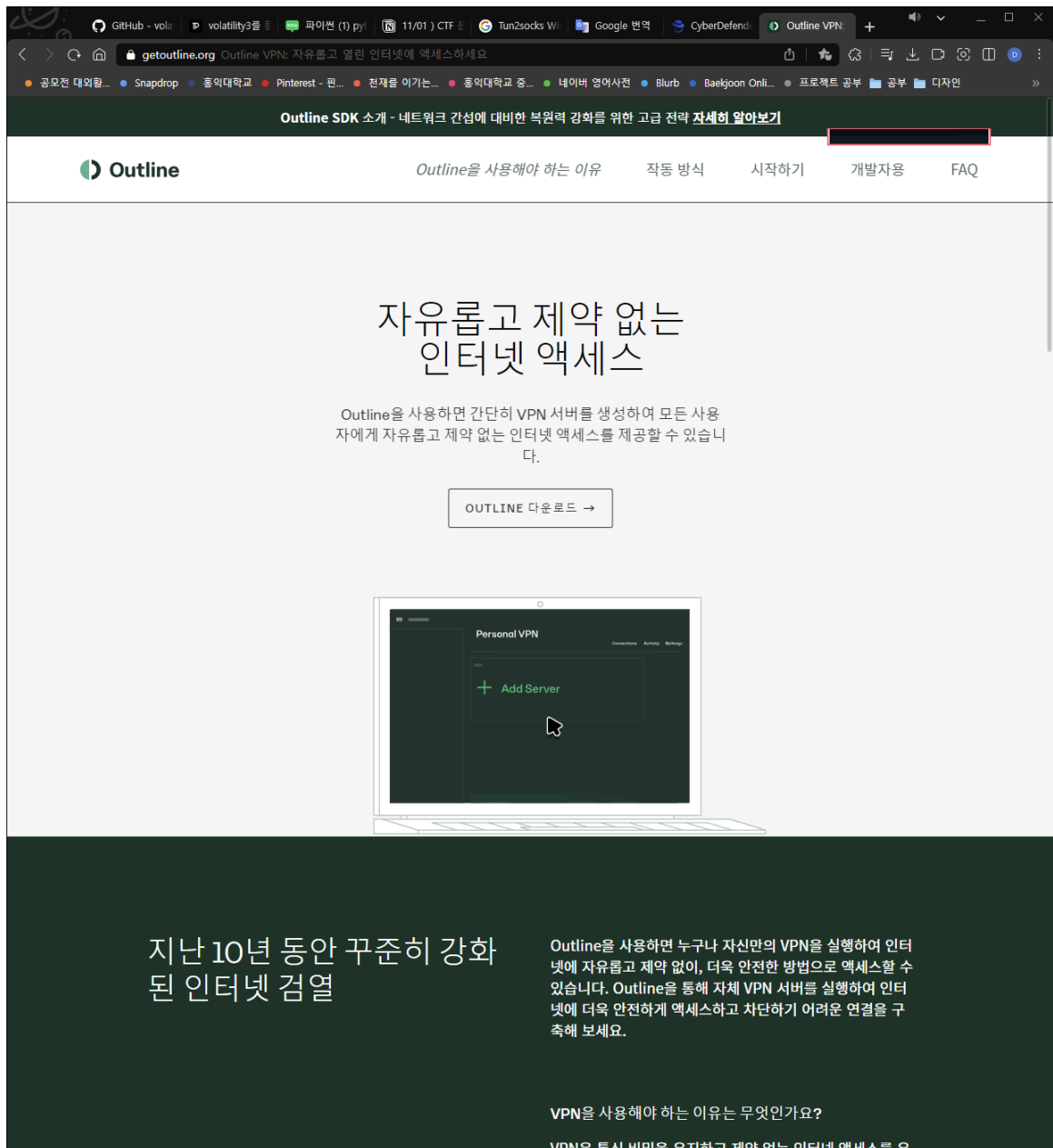
```
python3 vol.py -c config.json -f .\MemoryDump.mem  
windows.malfind.Malfind
```

여기서 Protection에 있는 것

```
PS C:\Users\PRO\바탕 화면> cd "C:\IHHH_Forensic\Volatility3-2.4.1\volatility3-2.4.1" > python3 vol.py -c config.json -f .\MemoryDump.mem windows_malfind.Malfind
Volatility 3 Framework 2.4.1
Progress: 100.00
PID      Process Start VPN      PDB scanning finished
End VPN Tag      Protection      CommitCharge      PrivateMemory      File output      Hexdump Disasm
-----
5896     oneatx.exe      0x400000      0x437fff      VadS      PAGE_EXECUTE_READWRITE      56      1      Disabled
4d 5a 90 00 03 00 00 00 MZ.....
04 00 00 00 ff ff 00 00 .....
b8 00 00 00 00 00 00 00 .....
40 00 00 00 00 00 00 00 @.....
00 00 00 00 00 00 00 00 .....
00 00 00 00 00 00 00 00 .....
00 00 00 00 00 00 00 00 .....
00 00 00 00 01 00 00 00 .....
00 00 00 00 00 00 00 00 .....
00 00 00 00 00 00 00 00 .....
4d 5a 90 00 03 00 00 00 04 00 00 00 ff ff 00 00 b8 00 00 00 00 00 00 00 40 00 00 00 00 00 00 00
00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 01 00 00
7540     smartscreen.ex 0x2505c140000 0x2505c15ffff VadS      PAGE_EXECUTE_READWRITE      1      1      Disabled
48 89 54 24 10 48 89 4c H.T$.H.L
24 08 4c 89 44 24 18 4c $.L.D$.L
89 4c 24 20 48 8b 41 28 .L$.H.H.A(
48 8b 48 08 48 8b 51 50 H.H.H.QP
48 83 e2 f8 48 8b ca 48 H...H..H
b8 60 00 14 5c 50 02 00 .'..P..
00 48 2b c8 48 81 f9 70 H+..H.p
83 e2 f8 48 8b ca 48 b8 60 00 14 5c 50 02 00 00 48 2b c8 48 81 f9 70 0f 00 00 76 09 48 c7 c1
```

A4. outline.exe

대충 VPN 서비스인듯



Q5. attacker's IP address

A5. 🙄

IP address라길래 netscan을 해봤는데 실행이 되지 않음

```
Windows PowerShell
PE TimeDateStamp      Wed Jun 28 04:14:26 1995
PS C:\Users\PRO\바탕 화면\3-2\IHHH_Forensic\volatility3-2.4.1\volatility3-2.4.1> python3 .\vol.py -f .\MemoryDump.mem wi
ndows.netscan
Volatility 3 Framework 2.4.1
usage: volatility [-h] [-c CONFIG] [--parallelism [{processes,threads,off}]] [-e EXTEND] [-p PLUGIN_DIRS]
                 [-s SYMBOL_DIRS] [-v] [-l LOG] [-o OUTPUT_DIR] [-q] [-r RENDERER] [-f FILE] [--write-config]
                 [--save-config SAVE_CONFIG] [--clear-cache] [--cache-path CACHE_PATH] [--offline]
                 [--single-location SINGLE_LOCATION] [--stackers [STACKERS ...]]
                 [--single-swap-locations [SINGLE_SWAP_LOCATIONS ...]]
                 plugin ...
volatility: error: argument plugin: invalid choice windows.netscan (choose from banners.Banners, configwriter.ConfigWrit
er, frameworkinfo.FrameworkInfo, isfinfo.IsfInfo, layerwriter.LayerWriter, linux.bash.Bash, linux.check_afinfo.Check_afi
nfo, linux.check_creds.Check_creds, linux.check_idt.Check_idt, linux.check_modules.Check_modules, linux.check_syscall.Ch
eck_syscall, linux.elfs.Elfs, linux.envvars.Envvars, linux.iomem.IOMem, linux.keyboard_notifiers.Keyboard_notifiers, linu
x.kmsg.Kmsg, linux.lsmmod.Lsmmod, linux.lsof.Lsof, linux.malfind.Malfind, linux.mountinfo.MountInfo, linux.proc.Maps, linu
x.psaux.PsAux, linux.pslist.PsList, linux.psscan.PsScan, linux.pstree.PsTree, linux.sockstat.Sockstat, linux.tty_check.Tt
y_check, mac.bash.Bash, mac.check_syscall.Check_syscall, mac.check_sysctl.Check_sysctl, mac.check_trap_table.Check_trap_
table, mac.ifconfig.Ifconfig, mac.kauth_listeners.Kauth_listeners, mac.kauth_scopes.Kauth_scopes, mac.kevents.Kevents, m
ac.list_files.List_Files, mac.lsmmod.Lsmmod, mac.lsof.Lsof, mac.malfind.Malfind, mac.mount.Mount, mac.netstat.Netstat, mac
.proc_maps.Maps, mac.psaux.PsAux, mac.pslist.PsList, mac.pstree.PsTree, mac.socket_filters.Socket_filters, mac.timers.Ti
mers, mac.trustedbsd.Trustedbsd, mac.vfsevents.VFSevents, timeliner.Timeliner, windows.bigpools.BigPools, windows.callba
cks.Callbacks, windows.cmdline.CmdLine, windows.crashinfo.Crashinfo, windows.devicetree.DeviceTree, windows.dllexport.Dl
list, windows.driverirp.DriverIrp, windows.drivermodule.DriverModule, windows.driverscan.DriverScan, windows.dumpfiles.Du
mpFiles, windows.envvars.Envvars, windows.filescan.FileScan, windows.getservicesids.GetServiceIDs, windows.getuids.GetSID
s, windows.handles.Handles, windows.info.Info, windows.joblinks.JobLinks, windows.lldrmodules.LdrModules, windows.malfind
.Malfind, windows.mbrscan.MBRScan, windows.memmap.Memmap, windows.modscan.ModScan, windows.modules.Modules, windows.muta
ntscan.MutantScan, windows.poolscanner.PoolScanner, windows.privileges.Privs, windows.pslist.PsList, windows.psscan.PsSc
an, windows.pstree.PsTree, windows.registry.certificates.Certificates, windows.registry.hivelist.HiveList, windows.regis
try.hivescan.HiveScan, windows.registry.printkey.PrintKey, windows.registry.userassist.UserAssist, windows.sessions.Sess
ions, windows.ssdts.SSDT, windows.statistics.Statistics, windows.strings.Strings, windows.symlinkscan.SymlinkScan, windo
w.vadinfo.VadInfo, windows.vadwalk.VadWalk, windows.virtmap.VirtMap)
PS C:\Users\PRO\바탕 화면\3-2\IHHH_Forensic\volatility3-2.4.1\volatility3-2.4.1> python3 .\vol.py -f .\MemoryDump.mem |
```

Q6. malware family 이름

A6. Redline Stealer

이해가 되지 않아 😊

Q7. 공격자가 방문한 PHP file의 전체 URL

A7. <http://77.91.124.20/store/games/index.php>

악성파일이었던 oneetx.exe 메모리 덤프

명령어가 너무 헛갈린다 ...



```
python3 vol.py -f .\MemoryDump.mem [-o] [output_path] --pid 5896 --
dump
```

strings 실행



```
strings.exe [DMP_FILE] > [OUTPUT_NAME]
```

C:\Users\PRO\바탕 화면\3-2\HHH_Forensic\volatility3-2.4.1\volatility3-2.4.1\5896strings.log - Notepad++

파일(F) 편집(E) 찾기(F) 보기(V) 인코딩(N) 언어(L) 설정(O) 도구(D) 매크로 실형 플러그인 창 관리 2

pslist.log pstree.log cmdline.log filescan.log driverscan.log psscan.log 5896strings.log

```

525 Tammam
526 Downloads
527 /C:\
528 Users
529 Tammam
530 OneDrive
531 ZGp.
532 ZlxS[
533 Q29udGVudC1UeXB1OiBhcHBsaWNhdGlvbi94LXd3dy1mb3JtLXVybGVuY29kZWQ=
534 FWYnfKOp9vWV40DdMeB ezqv6RL9hIhplcYXN17Y9rWn16L1JTVqdyKxTX7b3YM=
535 Q29udGVudC1UeXB1OiBhcHBsaWNhdGlvbi94LXd3dy1mb3JtLXVybGVuY29kZWQ=
536 0504ce46646b0dc397a3c30d6692ec750504ce46646b0dc397a3c30d6692ec75
537 0504ce46646b0dc397a3c30d6692ec750504ce46646b0dc397a3c30d6692ec75
538 0504ce46646b0dc397a3c30d6692ec750504ce46646b0dc397a3c30d6692ec75
539 http://77.91.124.20/store/games/index.php
540 Q29udGVudC1UeXB1OiBhcHBsaWNhdGlvbi94LXd3dy1mb3JtLXVybGVuY29kZWQ=
541 0504ce46646b0dc397a3c30d6692ec750504ce46646b0dc397a3c30d6692ec75
542 hbin
543 wow64_microsoft-windows-streambufferengine_31bf3856ad364e35_none_2ff4328cac1e2d53
544 f256!sberes.dll
545 v!10.0.19041.1
546 bL0X
547 wow64_microsoft-windows-streambufferengine_31bf3856ad364e35_none_275617b728c469b1
548 SomeUnparsedVersionsExist
549 f256!sbe.dll
550 f256!sbeio.dll
551 v!10.0.19041.1
552 bL0h
553 wow64_microsoft-windows-subsys_31bf3856ad364e35_none_26949257dacdb09e
554 SomeUnparsedVersionsExist
555 v!10.0.19041.1

```

찾기 결과들 - (8 일치)

찾기 "77.91.124.20" (1 개 파일을 검색하여 1 개 파일에서 8 개 일치)

C:\Users\PRO\바탕 화면\3-2\HHH_Forensic\volatility3-2.4.1\volatility3-2.4.1\5896strings.log (8 일치)

줄 539: http://77.91.124.20/store/games/index.php

줄 577: http://77.91.124.20/store/games/index.php

줄 581: http://77.91.124.20/store/games/index.php

줄 881: 77.91.124.20

줄 882: 77.91.124.20

줄 883: 77.91.124.20

줄 884: 77.91.124.20

줄 886: 77.91.124.20

찾기 "5408" (1 개 파일을 검색하여 1 개 파일에서 1 개 일치)

찾기 "one" (1 개 파일을 검색하여 1 개 파일에서 2 개 일치)

찾기 "0xad8189b41080" (1 개 파일을 검색하여 0 개 파일에서 0 개 일치)

찾기 "0xad8189b41080" (6 개 파일을 검색하여 2 개 파일에서 2 개 일치)

찾기 "one" (6 개 파일을 검색하여 3 개 파일에서 8 개 일치)

Normal text file length: 15,626,057 lines: 1,741,189 Ln: 539 Col: 1 Sel: 41 | 1 Windows (CR LF) UTF-16 LE BOM INS

Q8. 악성 실행파일의 경로

A8. oneetx.exe 검색

```

154 DESKTOP-2HF6AEV
155 05932807985
156 Y|CACLS "
157 Y|CACLS "
158 Y|CACLS "
159 Y|CACLS "
160 Y|CACLS "
161 R" /E
162 ..\c3912af058
163 oneetx.exe
164 f058
165 Tamnam
166 2af058
167 Tamnam
168 C:\Users\Tamnam\C:\Users\Tamnam\AppData\Local\Temp\c3912af058\oneetx.exe
169 tartup
170 FILE0
171 FILE0
172 FILE0
173 FILE0
174 !"#%&'()*+,-./0123456789:;<=>?@ABCDEFGHIJKLMNPQRSTUVWXYZ[\]^_`abcdefghijklmnopqrstuvwxyz{|}~
175 ++---++
176 ++--
177 !"#%&'()*+,-./0123456789:;<=>?@ABCDEFGHIJKLMNPQRSTUVWXYZ[\]^_`abcdefghijklmnopqrstuvwxyz{|}~
178 ^%G<O_Z_'"
179 ---Ts>o_ZY
180 `Gi
181 gVGN
182 Provider
183 z`EHa
184 F"

```

찾기 결과들 - (16 일치)

```

찾기 "oneetx.exe" (1 개 파일을 검색하여 1 개 파일에서 16 개 일치)
C:\Users\PRO\wsg\3-2\IHHH_Forensic\volatility3-2.4.1\5896strings.log (16 일치)
163: oneetx.exe
168: C:\Users\Tamnam\C:\Users\Tamnam\AppData\Local\Temp\c3912af058\oneetx.exe
472: Y|CACLS "oneetx.exe" /P "Tamnam:N"&CACLS "oneetx.exe" /P "Tamnam:R" /E&echo Y|CACLS "..\c3912af058" /P "Tamnam:N"&CACLS "..\c3
305558: oneetx.exe
347131: oneetx.exe
366702: oneetx.exe
366724: oneetx.exe
375501: oneetx.exe
375505: oneetx.exe
394059: oneetx.exe
406742: oneetx.exe
411951: oneetx.exe
781624: {"a": "oneetx.exe", "v": ""},

```

Normal text file length: 15,626,057 lines: 1,741,189 Ln: 168 Col: 73 Pos: 2,425 Windows (CR LF) UTF-16 LE BOM INS

1. pstree or pslist
2. malfind → 메모리 보호 기법
3. 프로세스 구글링해서 찾기?
4. netscan → 연결된 IP 주소
5. malware family 이름
6. 악성파일 메모리 덤프 → strings → 키워드 검색

공부할 게 많구나 ...



- PAGE_EXECUTE_READWRITE → suspicious 왜냐면 그 메모리가 동적으로 할당되었
다는 뜻

커밋된 페이지의 영역에 대한 실행, 읽기 전용 또는 읽기/쓰기 액세스를 사용하도록 설정합니다.

(oneetx.exe 영역에 접근하지 못하게 막는다는 걸까?)

- 프로세스
 - runtime broker : 작업관리자 윈도우 프로세스
 - tiworker : 시스템 파일 무결성 검사 프로그램
 - HxTsr > 감염 가능성 있음
 - rundll32 > 악성코드로 사용될 수 있음
- malware family : 비슷한 공격을 하는 앱들 모아놓은 것
 - Malpedia
- Living off the Land (LotL) 공격

: 대상 pc에 이미 설치된 도구를 사용하거나 간단한 스크립트와 셸 코드를 메모리에서 직접 실행하는 공격

 - 어떻게 공격하는가? : 사용자가 공격파일이 있는 특정 사이트에 방문하는 등을 통해 Flash가 로드되고, Flash가 PowerShell 호출. 명령을 통해 중요한 데이터를 수집하는 셸 스크립트 다운로드
-

▼ MemLab2

<https://github.com/stuxnet999/MemLabs/tree/master/Lab 2>



Description

One of the clients of our company, lost the access to his system due to an unknown error. He is supposedly a very popular "**environmental**" activist. As a part of the investigation, he told us that his go to applications are browsers, his password managers etc. We hope that you can dig into this memory dump and find his important stuff and give it back to us.

Note: This challenge is composed of 3 flags.

환경변수 볼 일이 있나보다...하고 넘어가기

먼저 로그 조사

———— profile —————

Win7SP1x64

—— suspicious process ——

- KeePass.exe(3008), ppid(1064-explorer.exe) → memdump, strings 해보기 > 필요 없을 듯
- notepad.exe (3260)

—— cmdline ——

- "C:\Windows\system32\notepad.exe"
C:\Users\SmartNet\Secrets\Hidden.kdbx >> 이거 머임?
0x000000003fb112a0 >> dumpfiles 해보기
- Destination = \??\C:\Users\SmartNet\Downloads\DumpIt\SMARTNET-PC-20191214-103843.raw

>> 이것도 뭔가 있어 보인다. 근데 dumpfiles가 안 됨

filescan에서 dumpit 검색해보니

\Device\HarddiskVolume2\Users\SmartNet\Downloads\DumpIt\DumpIt.exe.

이건 아무래도 dumpit에서 추출한 덤프파일인 듯.

1. Hidden.kdbx 조사

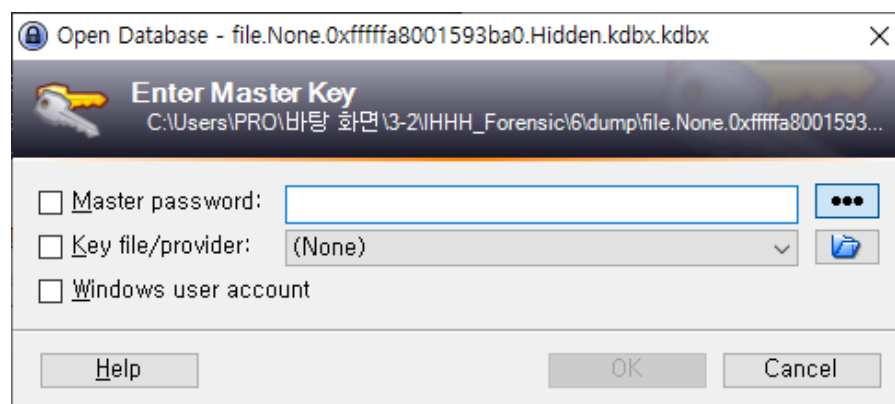
먼저 Hidden.kdbx를 dumpfiles 해준다.

kdbx를 구글링해보니 keepass로 다루는 파일 어찌구라 그래서 어떻게 해야하지 싶었는데 확장자명을 바꾼 뒤 keepass를 다운받아서 열면 된다고 한다...

▼ 참고) keepass란?

DB에 모든 암호를 저장해두고 하나의 master key를 지정해서 보관하는 소프트웨어 유통성을 발휘하자!!

file.None.0xfffffa8001593ba0.Hidden.kd... 2023-11-01 오후 6:40 KDBX 파일 4KB



근데 password 뭐임? 😅

일단 더 찾아봅시다.

+) 어딘가 패스워드가 있겠지 싶어 filescan에서 password 쳤더니 나옴!!! 짱신기

```
0x000000003fcec70 1 0 R--r-d \Device\HarddiskVolume2\Users\Alissa Simpson\Pictures\password.png
```

마찬가지로 추출한 뒤 png로 바꿔줬더니 이런 게 나왔다!!

MEM LABS

WOW! YOU ARE HERE!!

BUT THE FLAG IS NOT HERE!! :P

CHECK OUT THE BLOG BELOW :)

www.volatilevirus.home.blog

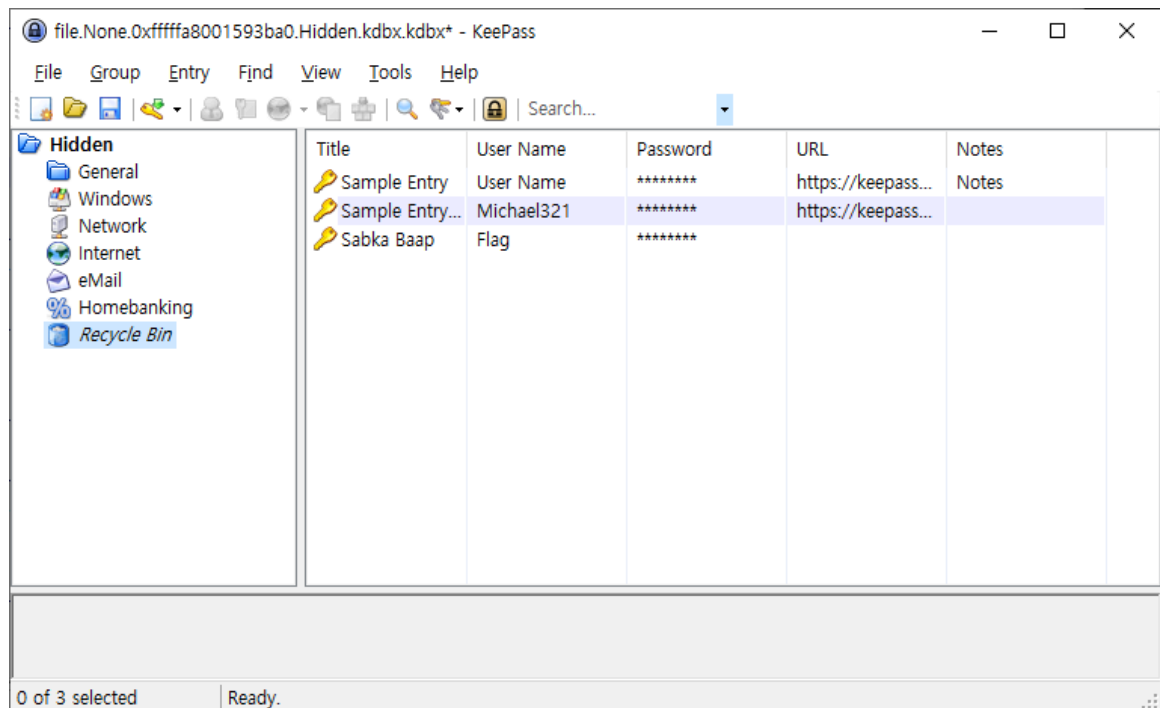
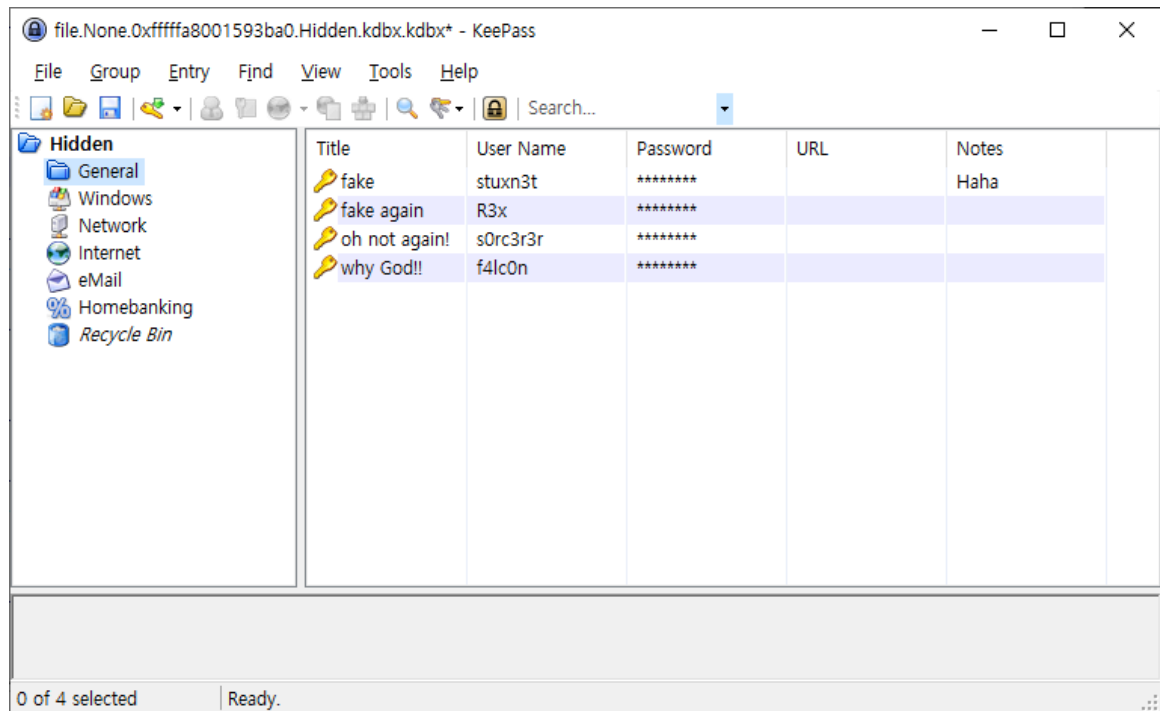
Psst!! password
is P4SSw0rd_123

- www.volatilevirus.home.blog >> 뭐지 블로그 홍보인가?
- 패스워드: P4SSw0rd_123

일단 db 파일을 열어봤다.

각각 General과 Recycle Bin 폴더에 키가 몇 개 있음

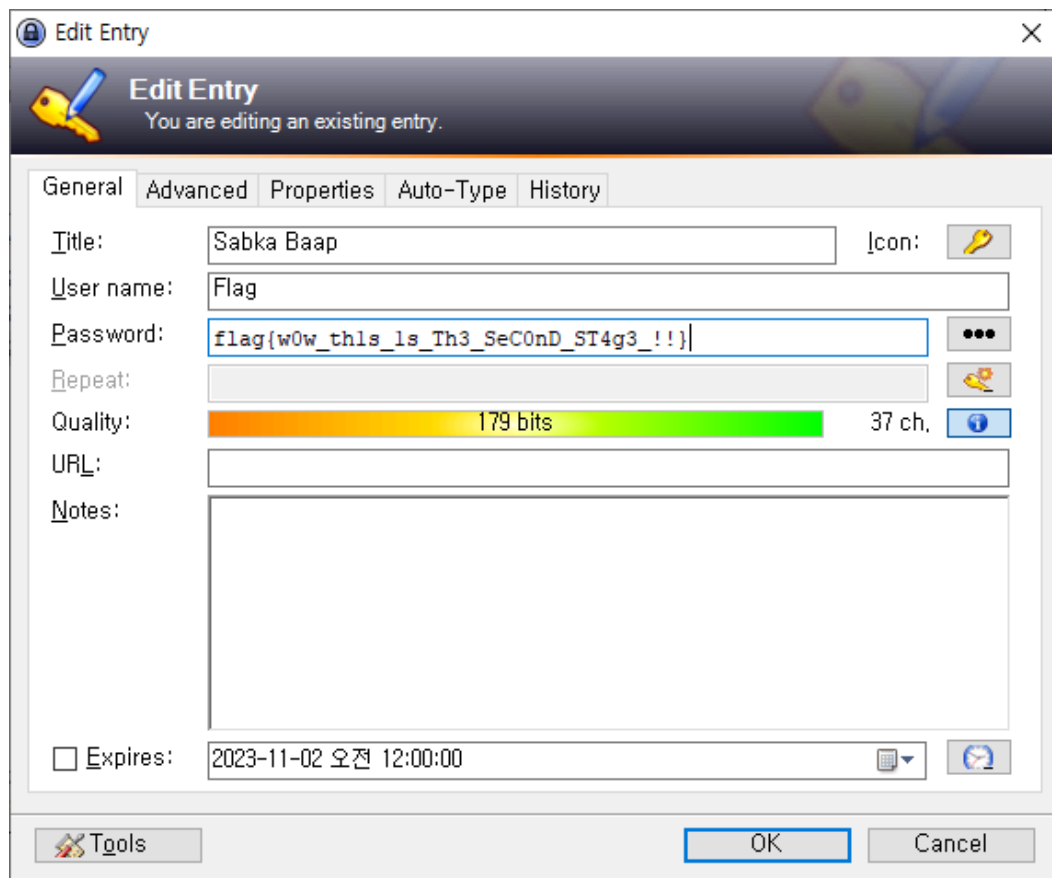
아무래도 fake는 건너뛰면 되는 것 같고



저기 Flag라고 쓰여 있다.

```
9GLfgqZ_wLSABKAMwZziY0QpA5Y8QSJvBF1D__  
CIi3jgYQ3bc9GLfgqZ_wLSABKAMwZziY0QpA5Y8QSJvBF1D__
```

sabka 검색해봤는데... base64도 아니고 이게 ...뭘까...?



그냥 열면 되는 거였음

두 번째 플래그 발견!

2. notepad.exe strings 파일 조사

>> 별 것 없었음

3. dumpit.exe

consoles에서 덤프파일 한 것 발견

```

Dump:
DumpIt - v1.3.2.20110401 - One click memory memory dumper
Copyright (c) 2007 - 2011, Matthieu Suiche <http://www.msuiiche.net>
Copyright (c) 2010 - 2011, MoonSols <http://www.moonsols.com>

Address space size:      1073676288 bytes (   1023 Mb)
Free space size:         23122788352 bytes (  22051 Mb)

* Destination = \??\C:\Users\SmartNet\Downloads\DumpIt\SMARTNET-PC-20191214-
103843.raw

```

smartnet>dumpit 경로가 계속 보여서 수상했다.

dumpfiles 해보니 악성코드였음!

strings 한 후 로그를 살펴봤다.

음... 근데 문제랑 관계는 없는 듯

```

:09:41 Attempting password change server/domain SmartNet-PC for user Alissa Simpson
12/11 19:09:42 SamChangePasswordUser2 on machine SmartNet-PC for user Alissa Simpson returned 0x0

```

Alissa Simpson 을 위해 password를 바꾸기 시도했다는 것?

Alissa Simpson이 공격자인가?

4. 환경변수 조사

ZmxhZ3t3M2xjMG0zX1QwXyRUNGczXyFfT2ZfTDRCXzJ9

>> flag{w3lc0m3_T0_\$T4g3_!_Of_L4B_2}

그냥 뒤져보다가 base64 같이 생긴 거 디코딩 해보니 플래그 나옴

여기까지 하고 구글링 해봤다

5. chrome.exe 조사

난 chrome을 생각 못 했는데,

아마 description에 browser 내용이 있어서 chrome도 수상한 거라고 추측

https://n1ght-w0lf.github.io/ctf_writeups/memlabs-lab2/

여기서는 plugin을 활용해 chromehistory를 바로 추출하는데

난 plugin 설치까지만 되고 명령어는 안 듣는다.

(+ 볼라틸리티 추가 플러그인들이 꽤 많은 것 같다.)

```
PS C:\Users\PRO\바탕 화면\3-2\IHHH_Forensic\6> git clone https://github.com/superponible/volatility-plugins
Cloning into 'volatility-plugins'...
remote: Enumerating objects: 91, done.
remote: Total 91 (delta 0), reused 0 (delta 0), pack-reused 91
Receiving objects: 100% (91/91), 63.49 KiB | 10.58 MiB/s, done.
Resolving deltas: 100% (43/43), done.
```

```
PS C:\Users\PRO\바탕 화면\3-2\IHHH_Forensic\6> volatility_2.6_win64_standalone.exe --plugins=plugins/ -f .\MemoryDump_Lab2.raw --profile=Win7SP1x64 chromehistory
Volatility Foundation Volatility Framework 2.6
ERROR : volatility.debug : You must specify something to do (try -h)
```

```
Volatility Foundation Volatility Framework 2.6
*** Failed to import volatility.plugins.chromehistory (ImportError: No module named csv)
*** Failed to import volatility.plugins.firefoxhistory (ImportError: No module named csv)
ERROR : volatility.debug : You must specify something to do (try -h)
```

```
PS C:\Users\PRO\바탕 화면\3-2\IHHH_Forensic\6> volatility_2.6_win64_standalone.exe --plugins=volatility-plugins/ -f .\MemoryDump_Lab2.raw --profile=Win7SP1x64 chromehistory
Volatility Foundation Volatility Framework 2.6
*** Failed to import volatility.plugins.chromehistory (ImportError: No module named csv)
*** Failed to import volatility.plugins.firefoxhistory (ImportError: No module named csv)
ERROR : volatility.debug : You must specify something to do (try -h)
```



그래서 그냥 chrome 메모리덤프 했다.

```
찾기 "http://" (1 개 파일을 검색하여 1 개 파일에서 862 개 일치)
C:\Users\PRO\바탕 화면\3-2\IHHH_Forensic\6\chrome.log (862 일치)
줄 737: t leave other traces, like cookies, on the computer after you close all open Guest windows. Any files you
줄 797: "http://www.w3.org/TR/html4/loose.dtd">
줄 3747: http://appldnld.apple.com/QuickTime/041-3089.20111026.Sxpr4/QuickTimeInstaller.exe
줄 4048: http://download.divx.com/player/divxdotcom/DivXWebPlayerInstaller.exe
줄 4088: http://support.apple.com/kb/HT203092
줄 4373: http://www.google.com/earth/explore/products/plugin.html
줄 4376: http://forms.real.com/real/realone/download.html?type=rpap_us
줄 4377: http://service.real.com/realplayer/security/02062012_player/en/
줄 4378: http://www.interoperabilitybridges.com/wmp-extension-for-chrome
줄 4424: http://fpdownload.macromedia.com/get/shockwave/default/english/win95nt/latest/Shockwave_Installer_Slim.exe
줄 4599: http://ao.microsoft.com/fwlink/?LinkID=149156
```

862개 일치

ㅋㅋ

어떻게 할까 생각하다가 윈도우 포렌식 때 들은 거 떠올림

chrome history가 저장되는 경로로 가보자!

윈도우 아티팩트에 나왔었다.

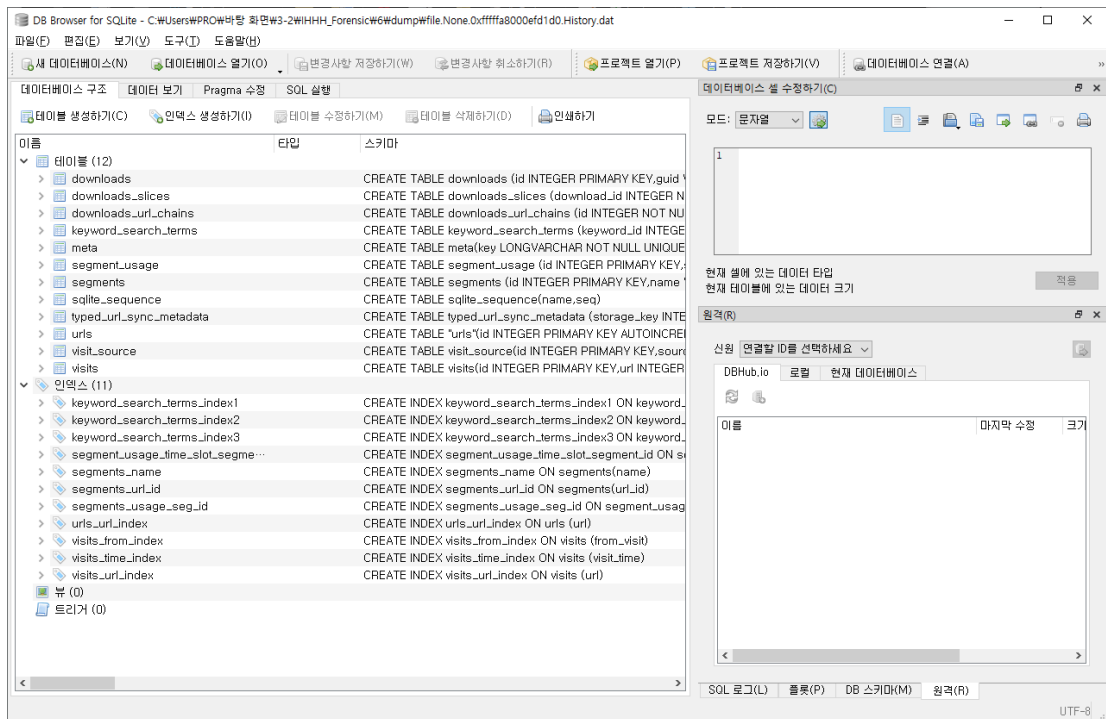


Chrome: %UserProfile%\AppData\Local\Google\Chrome\User Data\Default\

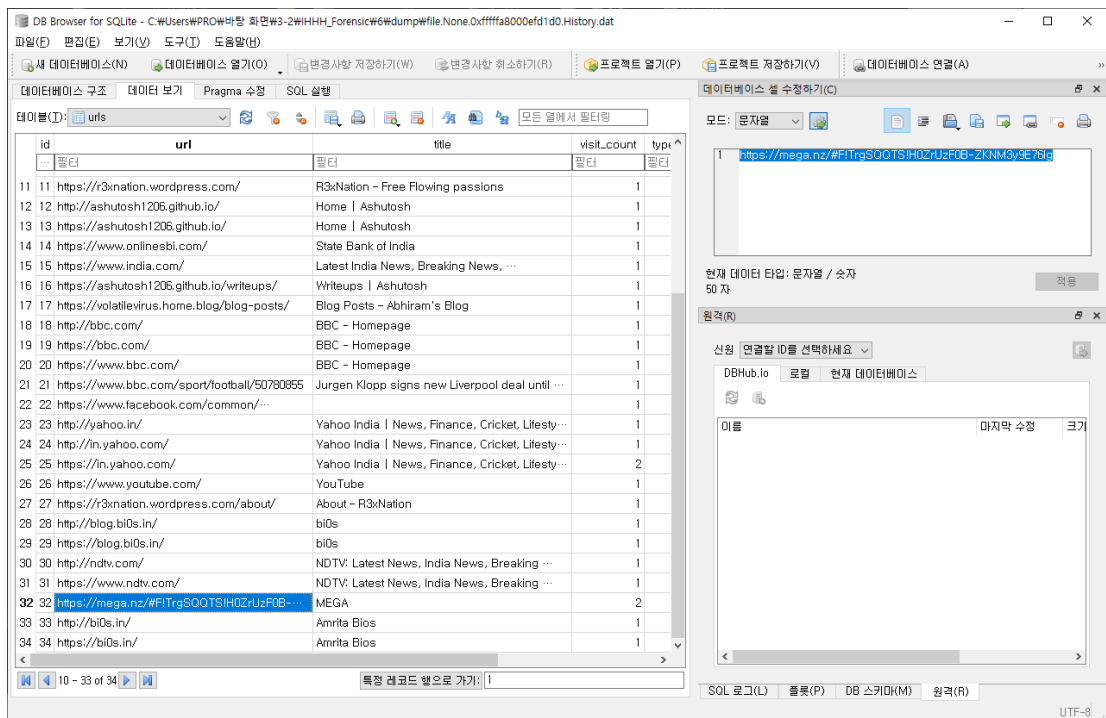
```
0x000000003fcfb1d0 18 1 RW-rw-
\Device\HarddiskVolume2\Users\SmartNet\AppData\Local\Google\Chrome\User Data\Default\History
```

dumpfiles 한다.

이건 db browser for sql로 열어야 함



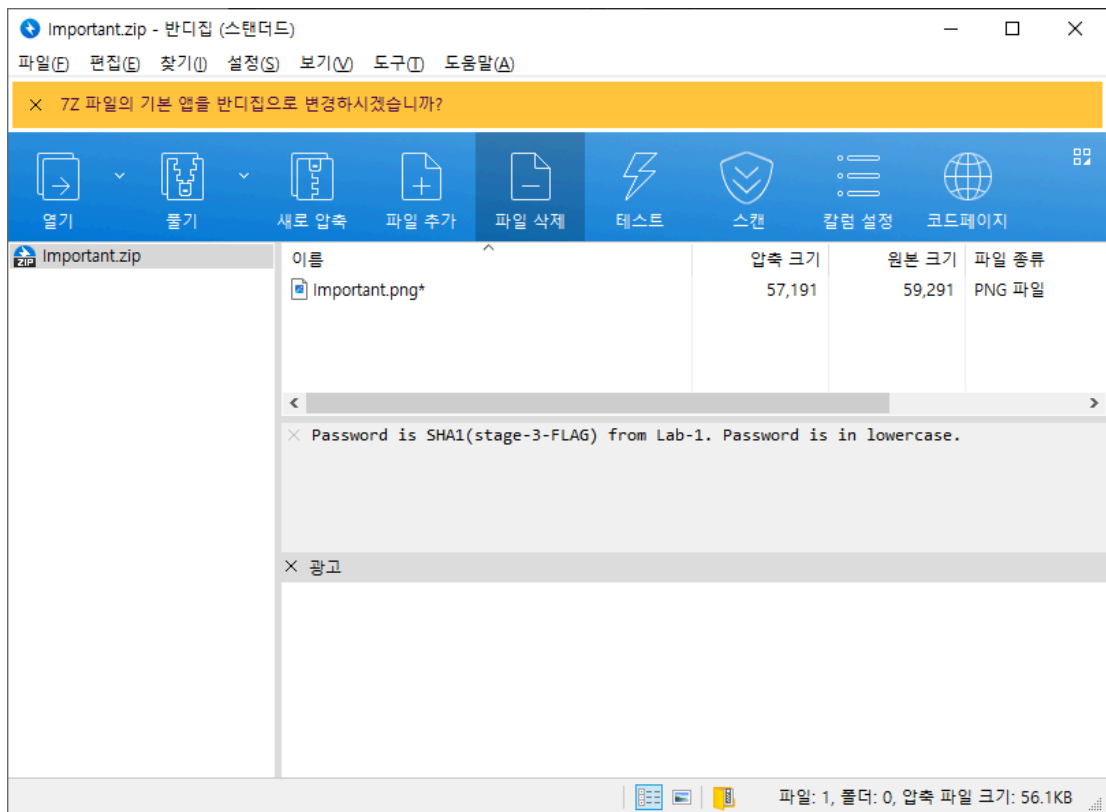
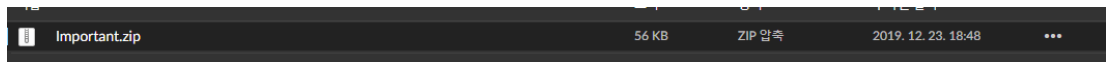
드디어!! 감동 😄



데이터 보기 → urls 살펴봄

mega(ctf 하는 사람들은 다 이걸 쓰나?) 사이트 발견

사실 여긴 뭘 봐야 되는지 몰라서 write-up 없으면 못 알아차렸을 듯



갑자기 Lab-1...

난 모르기 때문에 구글링의 힘을 빌렸다.

만약 내가 풀었더라면 되게 보람찼을 것 같음

1 flag{w3ll_3rd_stage_was_easy}

UpperCase

Hash Result in LowerCase

빈

SHA1 암호화

결과 복사

1 6045dd90029719a039fd2d2ebcca718439dd100a

zip 압축을 풀어준다.

flag{oK_So_
Now_St4g3_3
_is_DoNE!!}

**Congratulations on completing
LAB-2**

flag{oK_So_Now_St4g3_3_is_DoNE!!}
